

Security at AI Speed — Note for the Head of Regulatory Compliance

1. Why This Matters to You

Regulators do not operate at the speed of the attackers your organization now faces. By the time a framework, guideline, or supervisory expectation reaches you, the threat it was written to address has often already evolved. That gap is your exposure. A fully compliant organization can still be operationally obsolete — and when an incident becomes public, regulators will not ask whether you were compliant on paper. They will ask whether your decisions, your authorities, and your records held up against the actual speed of the event. Your role is no longer to demonstrate that controls exist. It is to ensure that the decisions the business will need to make under pressure are already defensible — in writing, in advance, with documented reasoning.

2. The Core Problem

Cyber risk used to be defined by control gaps. It is now defined by decision latency — the time between seeing a threat, deciding what to do, authorizing action, and acting. Attackers compress reconnaissance, access, movement, and impact into a single motion measured in minutes. Periodic governance, retrospective review, and human-speed escalation cannot keep up. Frameworks tell you what should exist; they do not tell you whether the organization can actually move when it has to. The dangerous illusion is that the presence of policy, audit cycles, and exception registers is the same as defensive readiness. It is not. An organization that cannot act inside the attacker's window is not protected by its compliance posture — it is narrated by it.

3. What You Must Own

- **Translating regulatory intent into pre-authorized operational decisions.** Not principles. Specific actions the business is permitted to take — disabling identities, isolating assets, degrading services, cutting access — when defined thresholds are met. With documented reasoning. Before the event.
- **The defensibility of those decisions under regulator scrutiny.** When a supervisor later asks *"why did you act?"* or *"why did you not?"*, the answer must already exist on paper, must have been reviewed before the incident, and must be owned by an accountable person.
- **Pre-cleared legal channels for collective defense.** Who can share what, with which peers, providers, and authorities, under what legal basis, and with whose sign-off — agreed *now*, not improvised during a live event. Ad-hoc legal review during an incident is decision latency dressed up as caution.
- **A defensible posture on artificial intelligence under uneven, emerging regulation.** Mapping shifting requirements onto concrete guardrails the business can execute without freezing innovation or accepting unmanaged exposure.
- **Audit and assurance that test executability, not paperwork.** Whether pre-authorized actions can actually be taken at speed — not whether a procedure document exists.
- **Being inside the loop, not downstream of it.** Compliance discovered late forces rework, regulatory surprises, and delayed authorities. You belong at the threat briefing, not after the incident report.

4. What Must Change Now

1. **From periodic review to continuous decision support.** Compliance attends the integrated threat and exposure briefing. It does not wait for a quarterly pack.

2. **From escalation to pre-authorization.** Disruptive actions are authorized in writing before they are needed, with the legal and regulatory reasoning attached. Authority delayed during an incident is authority surrendered.
3. **From case-by-case legal review to standing legal positions.** Information-sharing channels with peers, providers, and public authorities are cleared in advance — not negotiated while the clock is running.
4. **From form-based assurance to executability-based assurance.** Audit tests whether the organization can act inside the attacker's window — not whether the binder is complete.
5. **From paralysis on emerging artificial intelligence rules to documented, defensible positions.** Where guidance is unsettled, the organization writes down what it chose, why, who owns it, and what it would revise if rules sharpen. Paralysis is itself a decision — and one with consequences.

5. The One Question to Take Into the Boardroom

If a supervisor asked us tomorrow to produce — in writing — the disruptive actions we have pre-authorized, the reasoning behind them, and the person who signed them off, could we hand it over today? Or would we be improvising during the audit the same way we would improvise during the incident?